SECURITY

Package-Aware Integrity: From Source-Agnostic Publication to Full-System Attestation

Felipe Zimmerle *CTO, KonaSense*

Dhananjay Phadke *Principal Software Engineer, Microsoft*

OCP PLATINUM Member

One Blob, One Signature

- BMC firmware ships as a single signed image
- The bootloader verifies the whole blob, nothing smaller
- Change one package, re-sign the entire image
- No selective update, no mix-and-match verification
- No component traceability at runtime

The Gap Is the Package

- Build-time provenance: SBOMs, reproducible builds
- Runtime attestation: Caliptra RIM, SPDM
- The two meet only at whole-image granularity
- The package is the smallest buildable, auditable, updatable unit
- That is the granularity nobody attests

The Package as the Unit of Trust

BUILD

Every package is measured

Yocto hashes each file a package installs and folds them into one leaf.

one leaf per package

PUBLISH

The leaf enters an append-only log

Content-addressed, third-party auditable, source-agnostic.

signed tree head

BOOT

The device recomposes the root

Name-sorted, so one image has one root, the same on every boot.

root into PCR 14

PROVE

An inclusion proof ties the two together

This installed package is that published one, or it was never published.

Demo: One Package Was Never Published

- Five images of rpi3-openbmc, every one carrying a valid signature
- Image B: 2,131 packages, one of them unaccounted for
- dropbear 2026.91-r0 has no log entry under this image line, at tree size 2,163
- Whole-image verification passes on all five; only per-package verification separates them
- Live on the site, with a backup video

Verify it yourself: pkgattest.github.io/pkgattest

Publishing Side: The Transparency Log

BUILD

Every package is measured

Yocto hashes each file a package installs and folds them into one leaf.

one leaf per package

PUBLISH

The leaf enters an append-only log

Content-addressed, third-party auditable, source-agnostic.

signed tree head

BOOT

The device recomposes the root

Name-sorted, so one image has one root, the same on every boot.

root into PCR 14

PROVE

An inclusion proof ties the two together

This installed package is that published one, or it was never published.

Publishing Side: The Transparency Log

- Each package is published as a content-addressed entry
- Append-only log with signed tree heads
- Extends OCP S.A.F.E. SFR manifests and RIM work
- Append-only and checkable: consistency proofs catch a log that was rewritten
- Source-agnostic: any build, any vendor, one entry format

The Published Record: log-leaf-v1


```
{
 "arch": "cortexa53-nocrypto",
 "image_line": "rpi3-openbmc",
 "name": "dropbear",
 "pkg_leaf_hash": "113666841fca8888d26dfb7e1e6e56e285248581ea6d5430913e712f462b09ab",
 "schema": "log-leaf-v1",
 "version": "2026.92-r0"
}
```


included under signed tree head

pkg-log-sth-v1 2163 b987627ecf3932925507cd8beec2ee0f298669568746f17318f80d78214d2225 1787411123

This is the record for 2026.92-r0, the reviewed build. Image B ships 2026.91-r0, and no such record exists for it: that absence is the detection.

Pretty-printed for the slide. Canonical bytes are one line: keys sorted, no spaces, no trailing LF.
The tree head payload is signed with a trailing newline. Live record from the pkgattest log.

Verification Side: From Measurement to PCR

BUILD

Every package is measured

Yocto hashes each file a package installs and folds them into one leaf.

one leaf per package

PUBLISH

The leaf enters an append-only log

Content-addressed, third-party auditable, source-agnostic.

signed tree head

BOOT

The device recomposes the root

Name-sorted, so one image has one root, the same on every boot.

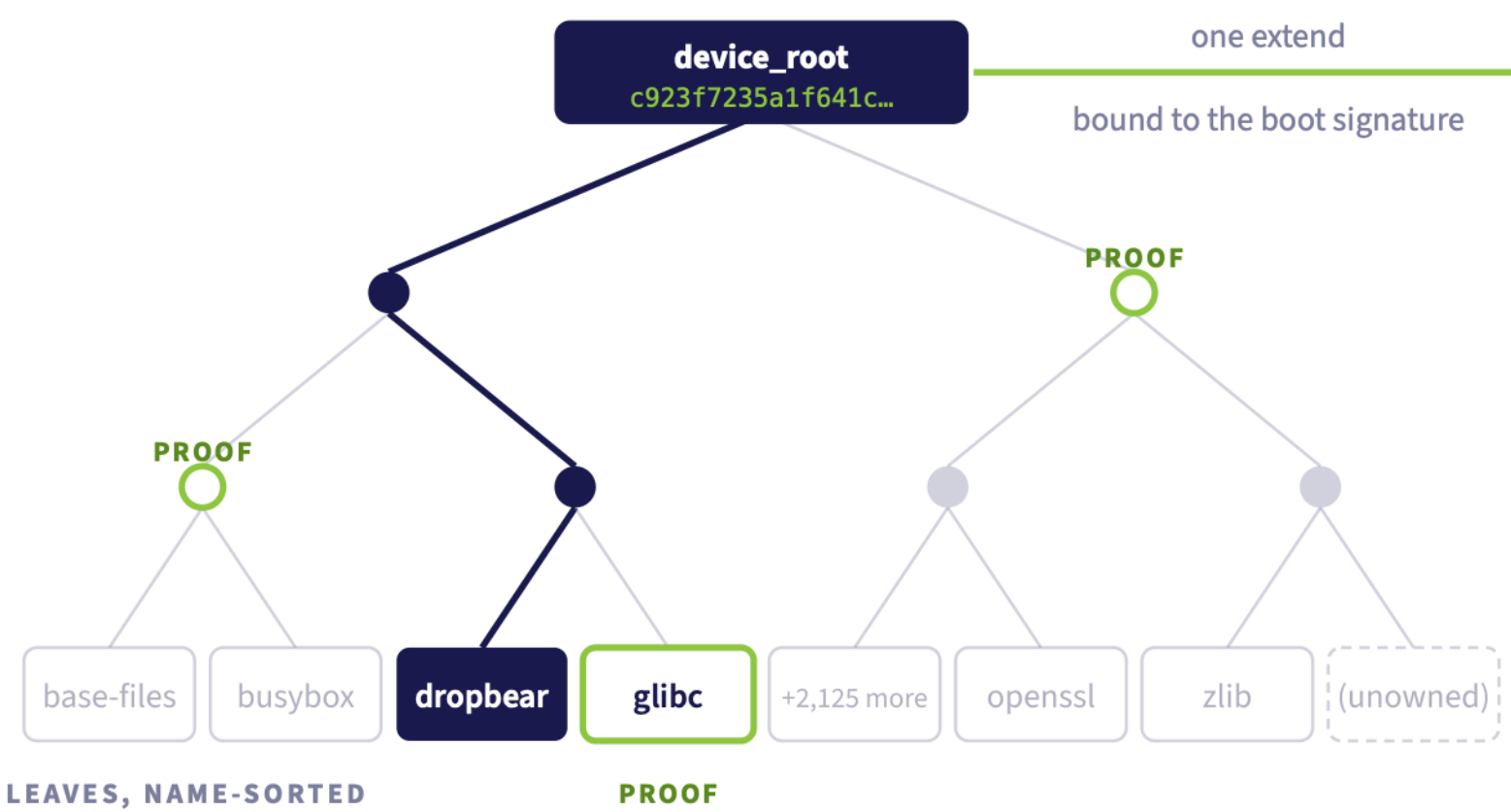
root into PCR 14

PROVE

An inclusion proof ties the two together

This installed package is that published one, or it was never published.

Verification Side: From Measurement to PCR



One root, any install order
Leaves are sorted by name, so the same image gives the same root.

Inclusion proof, offline
dropbear plus the 3 outlined hashes recompute the root; ~12 for 2,131.

Nothing left out
Files no package claims form one further leaf: (unowned).

The log records which versions exist; refusing an older one is a policy layer, not built.

Walkthrough: Yocto, Log, Boot, Proof

BUILD

Every package is measured

Yocto hashes each file a package installs and folds them into one leaf.

one leaf per package

PUBLISH

The leaf enters an append-only log

Content-addressed, third-party auditable, source-agnostic.

signed tree head

BOOT

The device recomposes the root

Name-sorted, so one image has one root, the same on every boot.

root into PCR 14

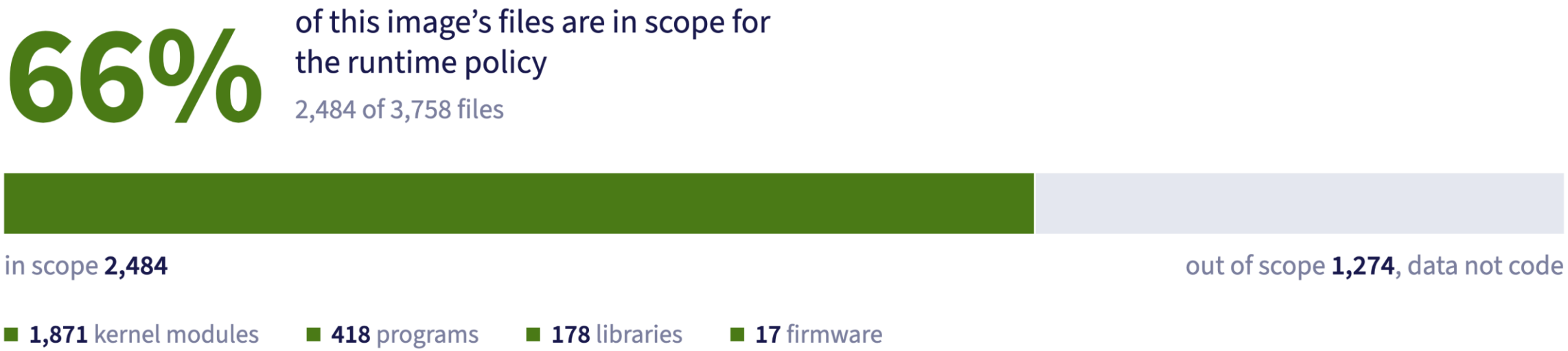
PROVE

An inclusion proof ties the two together

This installed package is that published one, or it was never published.

The Yocto layer: github.com/PkgAttest/pkgattest/tree/main/meta-pkg-integrity

How much runtime coverage a package-validated image can have



Linux IMA has evidence and no reference values. This has reference values and no evidence.
New verdicts: modified (bytes not the built ones) · unmeasured (it ran, no package owns it).

Scope, not observation: no device has booted this image, and PCR 10 is not extended. The demo TPM starts after IMA initialises, so the kernel runs in TPM-bypass. Load-time evidence, not runtime.

An OCP Integration: One New Field

```
"device": {
  "fw_hash_sha2_384": "...",        one hash, and it does not decompose
  "components": {
    "manifest_type": "pkg-measurements-v1",
    "device_root": "c923f7235a1f641c8744875a807181805a925ca5d394c5bc1543f0d0f3ed8d72",
    "image_line": "rpi3-openbmc",
    "package_count": 2131
  }
}
```

These are the field names the worked example already uses, so a manifest that exists today fits.
device_root commits to 2,131 package measurements, and it is the same value the BMC extends into PCR 14.
An observation, not a submission: it has not been through an OCP Security Project call, no Security Review Provider has seen it, and nothing here is endorsed by OCP.

Call to Action

Problem to solve

BMC firmware is published as one image and attested as one hash. The package is named by neither.

How to get involved

We are asking for a slot on the OCP Security Project monthly call
github.com/PkgAttest: prototype, format definitions and the log, public today

What exists, and what does not

Public: a working prototype, four format definitions, a live transparency log
Not yet: an OCP specification

Where to find more

pkgattest.github.io/pkgattest: verify the log in your browser
opencompute.org/contributions: where this would land, if the call says it should

Log key, sha256 of the SPKI DER. The site ships the key in the same download as the signatures,
so compare it against this value, from outside that download:
8f9e0c76 84c61e1d 6ab8f0e8 5982c9be 9c573ebd b9f097f3 67f304f1 e6b9e125

Open Discussion

Every rebuild has collateral. An exercise for the room:

1. **Rebuild the image: did you invalidate the review, or only its name?**
2. **What is the smallest piece of firmware you can attest on its own today?**
3. **Who should run the second log, and what would make you trust it?**
4. **What changed between builds, or what is running now: which do you need first?**
5. **You already ship an SBOM: what would have to be true for it to be evidence?**

Demo

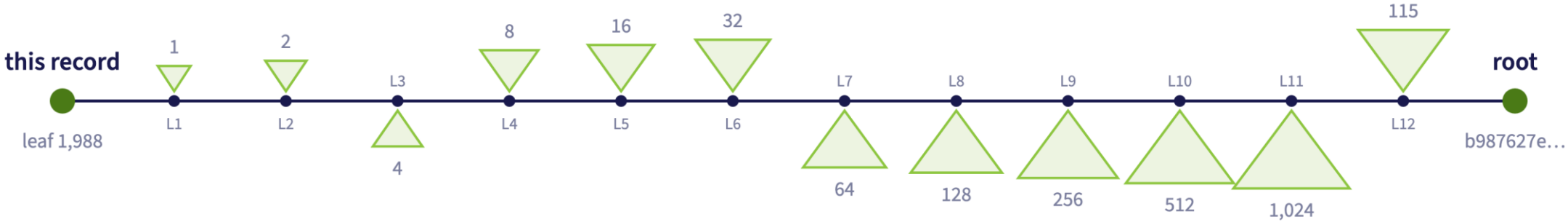
- Yocto Boot and Package "Attestation" on RPI.
  - Recorded demo, but the hardware is here running the image there for deep dive and questions.

Verify it yourself: pkgattest.github.io/pkgattest

Incremental Adoption, and the Ask

- Layers onto existing verified boot, no new root of trust
- Layers onto whole-image OTP anti-rollback, which stays exactly as it is
- Adoptable today, without re-architecting the platform
- The package is the unit of trust: review the proposal with us
- Security Project monthly call; the format definitions and prototype are public

Backup: One Inclusion Proof, 2,163 Records



12 triangles, 2,162 records between them: every record in the log except this one. Each triangle is a single hash standing for a whole subtree, which is why a proof this short covers a log this size. The sizes double all the way along except one: 115, because 2,163 is not a power of two and the last subtree is short.

This proof, live: pkgattest.github.io/pkgattest/#/pkg/openssl

Backup: Objections We Concede

- Why not Rekor? Reasonable: the log here is a demonstration, not a proposal
- What is proposed is the leaf semantics: a package measurement as a reference value, scoped to an image line
- CoRIM already carries per-component reference values and ships today, for a handful of blobs
- The argument is granularity: 2,131 packages inside one Linux image, not a new format
- Scale: publishing a third image added one leaf and reused 2,130, so the log grows by the delta

Backup: Objections That Stand

- One log, one key, no monitors, no gossip: not a transparency ecosystem, and there is no answer
- What publication buys is narrower than it sounds: divergence becomes detectable, nothing more
- An IMA log with no PCR behind it is a text file: simply right
- This board has no TPM; swtpm arrives after IMA initialises, so PCR 10 is never extended
- Measuring at rest says nothing about what is running: narrowed by verify-ima, not closed. TOCTOU stands

Backup: What an Update Does to an Assessment

- A finding about an artefact is a property of bytes: it follows an identical measurement exactly
- An absence of findings is a property of the review effort: it follows nothing
- Image A to image B: 2,130 identical measurements, 1 changed, 0 added or removed
- Common Criteria has Assurance Continuity: minor keeps the certificate, major forces re-evaluation
- OCP S.A.F.E. defines no equivalent, no expiry and no cadence, so an update drops you to zero

Backup: … in Three Vocabularies

- a package measurement · pkg-leaf-v1 · no S.A.F.E. term · RATS: Reference Value
- the log · transparency log · no S.A.F.E. term · RATS: Reference Value Provider
- the BMC · device.product · RATS: Attester
- the checker · pkgattest · RATS: Verifier
- Two rows have no OCP S.A.F.E. term at all. That gap is the proposal